

DigitMak Portal V1 — Преглед на изработеното

Изработиле:
Марија Манчева 231286
Филип Ташков 231164

1. Резиме

Порталот е modular monolith во еден .NET 10 Web API проект, со folder-based слоеви Web, Application, Domain и Infrastructure, EF Core, PostgreSQL, JWT автентикација, SignalR за разговор во реално време и Quartz.NET за закажани job-ови. Frontend е React + TypeScript + Vite, поделен на public/client/staff/admin делови и има поддршка за MK/EN/SQ. Главните V1 работни текови се присутни, а точка 13 ги наведува отворените инфраструктурни и интеграциски одлуки. Backend декларира 122 HTTP рути распределени во 7 контролерски групи.

2. Технологии и архитектура

- Backend: .NET Web API, Entity Framework Core, PostgreSQL, ASP.NET Core Identity, JWT, SignalR, Quartz.NET
- Frontend: React, TypeScript, Vite, React Router, i18next (EN/MK/SQ)
- Deployment: Docker Compose, Nginx, Let's Encrypt (Certbot), systemd и ClamAV конфигурација за production
- Архитектура: modular monolith со layered/onion-inspired организација во еден assembly. Не е строг onion распоред со зависности само навнатре, бидејќи Application кодот на повеќе места директно користи Infrastructure/Persistence типови.
- Повторно употребливите текови за тикети, состаноци, јавен контакт и јавна содржина се зад application-service и repository интерфејси; дел од административните read-only операции директно го користат PortalDbContext.
- Во тест-проектот се дефинирани 41 [Fact] и 1 [Theory] со 2 datasets, односно 43 xUnit тест-случаи за API, идентитет, тикети, состаноци, датотеки, известувања и инфраструктурни функции.

3. Модули според улога

Јавен дел (без најава)

- Услуги, содржински страници, поставки за јазици
- DMA-стил контакт формулар со целосна класификација (6 внатрешни DMA категории)
- Тренинг/LMS placeholder страница, страници за приватност и услови

Идентитет

- Регистрација, најава, верификација на email, заборавена/ресетирање лозинка
- Refresh token ротација и revoke: искористениот/повлечениот token се одбива, а старите записи автоматски се чистат. Нема посебна token-family реакција при повторна употреба на украден стар token.
- Лозинка минимум 10 знаци, потврда на email задолжителна пред најава

Клиент (претплатник)

- Организација (креирање, преглед), барања за промена на профил/сметка со admin одобрување
- Претплата — преглед на тековната/последната претплата, активна покана и инструкции за офлајн плаќање; нема посебен клиентски endpoint за целосна историја.
- Тикети — „Мои тикети“, отворање нов тикет, разговор во реално време, прилози
- Состаноци — „Мои состаноци“, барање нов, откажување/промена на термин, преземање .ics

Персонал (help-desk агент / експерт)

- Разгледување и доделување тикети, промена на статус, внатрешни белешки (не се гледаат од клиент)
- Состаноци за персонал — преглед, потврда/одбивање, .ics извоз
- Help-desk агентите можат да ги прегледуваат контакт-барањата; организациски детали се ограничени според улога и поврзаност со доделен тикет/контакт. Експерт нема пристап до листата на контакт-барања.

Администратор

- Корисници и улоги, одобрување организации, покани и активирање претплати
- Контакт барања — доделување, обработка, поврзување со организација
- Тикети — целосен преглед; состаноци — „мои закажани“ + директно закажување состанок за клиент
- Content/услуги, системски поставки, докази (evidence) и темплејти за докази
- Аудит логови (append-only) и извештаи (претплати, тикети, KPI, CSV export)

4. Работни текови (клучни примери)

Организација и претплата

Корисникот се регистрира и го потврдува email, потоа се приклучува кон организација. Организацијата стои во статус PendingApproval сè додека админ не ја одобри. Дури откако организацијата е одобрена, админ може да испрати покана за лична претплата; корисникот ја прифаќа, статусот станува PendingPayment, плаќањето се врши офлајн, а активацијата ја прави админ рачно. Претплатата трае 12 месеци и автоматски истекува преку закажан јоб.

Тикет

Само клиент со одобрена организација и активна, неистечена лична претплата може да креира тикет; ова се проверува server-side при креирањето. Потоа тикетот тргнува како New, се доделува на агент/експерт (Assigned) и може да премине во InProgress. Деталите, разговорот и прилозите се заштитени со проверка на сопственик/доделен персонал/admin, но активната претплата не се проверува повторно на секоја порака или upload. Разговорот е преку SignalR, внатрешните белешки се само за персонал, а тикетот завршува со финална и по потреба referral препорака.

Состанок

Претплатник бара состанок директно или од конкретен тикет, со преферирано време/временски прозорец. Персоналот може да потврди, одбие, заврши или предложи друг термин. Потврдениот состанок се прикажува во календарските прегледи, се редат email известувања, а состаноците може да се извезат како .ics фајл.

5. Известувања

Ивестувањата се запишуваат во база со статус Queued и NotificationDispatchJob ги обработува секоја минута преку Brevo SMTP, со повторни обиди и exponential backoff. Истите записи се користат и за in-app листата/бројачот. Известувањето содржи Type, статус Queued/Sent/Failed, IsRead и по потреба ActionUrl за директно отворање тикет, состанок, организација или друг екран.

6. Тек на креирање тикет и прилози — одговор на прашањето

Во тековниот frontend формата „Нов тикет“ содржи категорија, наслов, опис и приоритет и нема поле за документ. По успешно креирање, клиентот го отвора деталниот преглед на тикетот и прикачува фајл преку POST /api/tickets/{id}/attachments. Backend endpoint прима и опционален messageId. Пред зачувување се проверуваат големина, дозволен content-type и extension, реален file signature и checksum.

Спецификацијата навистина предвидува посебен attachment endpoint и TicketAttachment со опционален message_id, но не пропишува дека frontend-от не смее да понуди фајл во истиот визуелен чекор. Исто така, PDF-от бара MIME/type валидација, додека virus scanning изречно може да се одложи. ClamAV е дополнување во кодот: во production compose е конфигуриран, а кога CLAMAV_HOST не е поставен (на пример локален development), скенирањето се прескокнува.

7. Безбедност и усогласеност

- JWT bearer автентикација со issuer/audience/lifetime валидација и потпишан клуч
- Refresh token ротација со revoke на искористениот token и одбивање на истечени/повлечени tokens; не е имплементирано автоматско повлекување на цела token-family при reuse детекција.
- Лозинка минимум 10 знаци, задолжителна email верификација пред најава
- Рејт-лимитирање на најава и јавниот контакт формулар
- Upload заштита: ограничување 1 B–10 MB, allow-list за MIME/extension, проверка на file signature, SHA-256 checksum и заштита од излез надвор од storage root. ClamAV скенира кога сервисот е конфигуриран; production compose го конфигурира задолжително.
- Append-only аудит лог за клучните дејствија во системот

- HTTPS redirect и HSTS во production, безбедносни HTTP headers и forwarded-header обработка зад Nginx. Тековната конфигурација ги чисти KnownProxies/KnownIPNetworks, па доверливиот проху опсег треба експлицитно да се ограничи пред production.

8. Извештаи и KPI

Административниот дел изложува KPI преглед и извештаи за претплати, тикети (збирно и детално), контакт-барања, состаноци и referral препораки. Постојат CSV export според V1 барањето и дополнителни форматиран Excel (.xlsx) exports по избран dataset.

9. Интернационализација

- Јазици: англиски, македонски (кирилица), албански
- Frontend-от има MK/EN/SQ resources, администраторската содржина користи преводи по поле, а enum кодовите се чуваат во база и се прикажуваат со frontend етикети. Email templates имаат MK/SQ/EN варијанти.

10. Ново додадено (надвор од оригиналната спецификација)

Следните ставки не се барани експлицитно, меѓутоа како девелопери мислење дека беа потребни на порталот :

- ClamAV IFileScanner и production ClamAV container; локално скенирањето се прескокнува ако сервисот не е конфигуриран.
- Рејт-лимитирање на најава и јавниот контакт формулар, безбедносни HTTP headers
- Барања за промена на профил/сметка (Account Change Requests) со admin одобрување
- Evidence темплејти (EvidenceTemplate) — спецификацијата изречно го одложува ова за подоцна, но во кодот веќе постои основна имплементација
- ICS (.ics) извоз за клиент и персонал, погоден за увоз во Google Calendar/Outlook
- Moodle launch со ExternalLink и HMAC-SHA256 SignedLaunch; постои и конфигурациска поддршка за OIDC/SAML entry URL, но не и целосен локален OIDC/SAML callback flow.
- Production validation скрипти (PowerShell/sh) кои проверуваат дека нема заборавени CHANGE_ME вредности, дека JWT клучот и лозинките се доволно силни и дека доменот е HTTPS
- Backup/restore скрипти со rehearsal (пробно обновување), acceptance test скрипта, systemd конфигурација и Nginx/TLS init скрипта
- Health checks endpoint и automate-production скрипта за целосно автоматизиран production setup
- Quartz.NET scheduler со 4 job-ови: TicketEscalationJob на 30 минути (ескалација по 24 часа), SubscriptionMaintenanceJob на 15 минути, NotificationDispatchJob на 1 минута со exponential backoff и DataRetentionCleanupJob секоја ноќ.
- Известувањата имаат поле ActionUrl (deep link) — клик на известувањето води директно до конкретниот тикет, состанок, организација и сл.
- Состаноците се одделени по улога: „Мои состаноци“ за клиент, состаноци за персонал/staff и посебен админ преглед „мои закажани“ — плус админ може директно да закаже состанок за клиент
- Форматиран Excel (.xlsx) exports покрај CSV извештаите побарани во V1.

11. CI/CD

Кога ќе се додаде pipeline, production secrets треба да се внесат како GitLab protected variables или безбедно монтирани environment secrets.

12. Demo пристап (само локално; не за production)

Улога	Email	Лозинка
Администратор	admin@digitmak.mk	DigitMak!2026Admin
Клиент (со одобрена организација и активна претплата)	client@digitmak.mk	DigitMak!2026Client

Доколку сакате, можете и Вие да создадете test-account.

13. Отворени точки (чекаат одлука/влезни податоци)

- Финален VM (CPU/RAM/диск), staging домен
- Финални Brevo SMTP податоци и период на чување фајлови/бекапи
- Визуелен дизајн/брендирање
- Moodle SSO протокол/договор со сопственикот на Moodle и одлука дали ќе се користи ExternalLink, SignedLaunch или вистински OIDC/SAML provider flow.
- Google/Microsoft calendar нативна синхронизација: кодот има .ics export и генерира OAuth authorization URL кога има credentials, но нема callback, token storage и event sync; ова останува за V2.
- Forwarded headers треба да се ограничат на конкретниот Nginx proxy/network наместо да се прифаќаат без експлицитна trusted-proxy листа.